

Initial Post (Peer A)

by Peer A - Wednesday, 10 June 2026, 6:26 AM

Wunder et al. (2024) criticise the Common Vulnerability Scoring System (CVSS) for not consistently achieving the purpose of a standardised vulnerability scoring framework. CVSS is intended to provide comparable numerical severity scores across evaluators, but the study shows that different evaluators may assign different values to the same vulnerability. The authors identify several problematic characteristics, including reliance on human interpretation, ambiguity in metric definitions, and the use of CVSS beyond its intended role as a severity measure. In particular, Attack Vector, User Interaction and Scope are highlighted as metrics that are often evaluated inconsistently. Scope appears especially difficult because evaluators must decide whether exploitation affects only the vulnerable component or extends into another security scope.

This critique is persuasive because vulnerability management depends on reliable and actionable assessments. If CVSS scores vary between evaluators, organisations may allocate remediation resources inefficiently. Wunder et al. (2024) also show that inconsistency is not only linked to evaluator experience, but to properties of CVSS itself, including problematic metrics and documentation. This supports Spring et al.'s (2021) argument that CVSS has important limitations when used beyond technical severity, particularly because it does not adequately account for context, consequences or stakeholder-specific priorities. However, CVSS should not be dismissed entirely. It remains useful as a shared language for communicating severity across technical teams, vendors and customers. The problem is its use as the main basis for deciding which vulnerabilities should be addressed first.

One alternative discussed by Wunder et al. (2024) is Stakeholder-Specific Vulnerability Categorization (SSVC). SSVC should replace CVSS as the primary prioritisation method because it is decision-oriented rather than score-oriented. Instead of producing a general numerical severity rating, SSVC uses stakeholder-specific decision trees to guide vulnerability response (Spring et al., 2020). This is more suitable for operational security because different organisations face different exposure, mission impact and response constraints. A vulnerability with a high CVSS score may not always require the same action in every environment. By contrast, SSVC helps decision-makers connect vulnerability information to practical outcomes, such as whether to defer, track, schedule or act. Therefore, CVSS may remain valuable for severity communication, but SSVC provides a more appropriate basis for prioritising vulnerability response.

References

Spring, J.M., Hatleback, E., Householder, A., Manion, A. and Shick, D. (2020) 'Prioritizing vulnerability response: A stakeholder-specific vulnerability categorization (Version 1.1)', *Workshop on the Economics of Information Security*.

Spring, J.M., Hatleback, E., Householder, A., Manion, A. and Shick, D. (2021) 'Time to change the CVSS?', *IEEE Security & Privacy*, 19(2), pp. 74–78. doi: 10.1109/MSEC.2020.3044475.

Wunder, J., Kurtz, A., Eichenmüller, C., Gassmann, F. and Benenson, Z. (2024) 'Shedding light on CVSS scoring inconsistencies: A user-centric study on evaluating widespread security vulnerabilities', *2024 IEEE Symposium on Security and Privacy (SP)*, pp. 1102–1121. doi:10.1109/SP54263.2024.00058.

My Peer Response

by Séba Daher - Friday, 12 June 2026, 5:52 AM

(Evidence: <https://www.my-course.co.uk/mod/forum/discuss.php?d=370203#p747586>)

Peer A's separation of CVSS for communicating severity from SSVC for prioritisation is well drawn. The point that the same score can call for different responses in different environments captures exactly where the environment-agnostic Base Score falls short in practice. The shared case for SSVC becomes stronger if we also consider what would make the replacement claim fully defensible.

Two points sharpen that case rather than oppose it. First, the SSVC authors describe their decision trees as a hypothesis that still needs empirical testing before it can be treated as fit for use, not as a settled replacement (Spring et al., 2020). Saying this openly makes the argument more credible, because it shows that adoption should follow evidence. Second, a decision tree does not remove subjective judgement; it moves that judgement to the individual decision points. Cox (2008) shows that ordinal categorisation schemes often have poor resolution and can rank items inconsistently when the category boundaries are unclear. Take the decision point that asks whether a vulnerability is being actively exploited or only has proof-of-concept code. Evaluators could easily read the same evidence differently. If that happens, SSVC would produce the same disagreement between raters that Wunder et al. (2024) found with the Scope metric.

These caveats do not defeat the argument for replacing CVSS; they strengthen it. The position holds up better once it accepts that SSVC still needs the validation its own authors call for, and that decision points must be clearly defined to keep subjectivity in check. A study like Wunder et al.'s, but testing whether SSVC categorises more consistently than CVSS, would turn a promising proposal into a justified standard.

References

Cox, L.A. (2008) 'What's wrong with risk matrices?', *Risk Analysis*, 28(2), pp. 497-512. doi:10.1111/j.1539-6924.2008.01030.x.

Spring, J., Hatleback, E., Householder, A., Manion, A. and Shick, D. (2020) 'Prioritizing vulnerability response: a stakeholder-specific vulnerability categorization (version 1.1)', Workshop on the Economics of Information Security. Brussels, Belgium, December.

Wunder, J., Kurtz, A., Eichenmüller, C., Gassmann, F. and Benenson, Z. (2024) 'Shedding light on CVSS scoring inconsistencies: a user-centric study on evaluating widespread security vulnerabilities', 2024 IEEE Symposium on Security and Privacy (SP), pp. 1102-1121. doi:10.1109/SP54263.2024.00058.

Initial Post (Peer B)

by Peer B - Saturday, 13 June 2026, 10:48 AM

The Common Vulnerability Scoring System (CVSS) has become one of the most popular methods for assessing and prioritising software vulnerabilities. However, after reading the article by Wunder et al. (2024), I understand why many researchers are beginning to question its effectiveness. The authors note that while CVSS is intended to offer a standardised means of measuring the severity of a vulnerability, different analysts often rate the same vulnerability differently. The study revealed substantial inconsistencies between evaluators, suggesting that CVSS is not as objective as many organisations believe.

I agree with the criticism of the authors. Theoretically, a normal scoring system should produce similar results regardless of who is performing the assessment. But CVSS does have metrics like 'Attack Complexity', 'User Interaction' and 'Privileges Required' which require human judgement. As a result, different security professionals may have different opinions about the same vulnerability and give it different scores. This results in inconsistent patching priorities and inefficient security resource utilisation.

The authors also point out that CVSS focuses mostly on technical severity rather than on the likelihood of a vulnerability being exploited in practice. I think this issue is another important limitation. Organisations often have limited resources and need to focus on vulnerabilities that pose the greatest practical risk, not just those with the highest severity scores. Similar concerns were also expressed by Johnson et al. (2018), stating that CVSS scores do not always correctly reflect real-world risk.

Wunder et al. (2024) studied alternatives, and in my opinion, the Exploit Prediction Scoring System (EPSS) is the best alternative to CVSS. CVSS measures the potential severity, while EPSS assesses the likelihood of a vulnerability being exploited. This approach offers security teams information that can be directly applied to risk-based decision-making. A vulnerability with a low CVSS score but a high probability of exploitation might warrant more immediate attention than a high-severity vulnerability unlikely to be exploited.

In conclusion, I don't think CVSS should be thrown away; it still provides a useful measure of technical severity. If, however, organisations have to choose one framework for vulnerability prioritisation, EPSS is more practical and realistic, as it bases its priorities on the likelihood of real attacks rather than on theoretical impact alone.

References

Johnson, P., Lagerström, R., Ekstedt, M. and Franke, U. (2018) 'Can the Common Vulnerability Scoring System be trusted? A Bayesian analysis', *IEEE Transactions on Dependable and Secure Computing*, vol. 15, no. 6, pp. 1002–1015.

Wunder, J., Kurtz, A., Eichenmüller, C., Gassmann, F. and Benenson, Z. (2024) 'Shedding light on CVSS scoring inconsistencies: A user-centric study on evaluating widespread security vulnerabilities', Proceedings of the IEEE Symposium on Security and Privacy, 1–18.

Peer Response

by Peer A - Tuesday, 16 June 2026, 5:57 AM

This post provides a clear discussion of why CVSS may create difficulties in vulnerability prioritisation, particularly when analysts interpret the same vulnerability differently. The issues highlighted could potentially be reduced through several preventive measures. First, organisations should avoid using CVSS as a standalone prioritisation mechanism. Since CVSS mainly measures technical severity, it should be combined with contextual information such as asset criticality, exposure, exploit availability, business impact and operational risk. This would help prevent remediation decisions from being based only on a numerical severity score, which may not reflect real-world risk (Wunder et al., 2024).

Second, inconsistent human judgement could be reduced through internal scoring standards. Organisations could develop concise CVSS scoring playbooks that define how difficult metrics, such as Attack Complexity, User Interaction and Privileges Required, should be interpreted in common scenarios. These playbooks should include worked examples and should be reviewed regularly. In addition, calibration sessions between security analysts could help ensure that similar vulnerabilities are assessed more consistently across the team.

Third, EPSS could be used alongside CVSS to improve prioritisation. As noted in the post, EPSS focuses on the likelihood of exploitation rather than technical severity alone. This could help organisations identify vulnerabilities that may require urgent remediation even when their CVSS score is not the highest (Jacobs et al., 2021). However, EPSS should also be governed by a clear process, including analyst review and business-context assessment, to avoid replacing one isolated score with another.

Overall, a more suitable preventive approach would combine CVSS, exploit-likelihood data, organisational context and peer review within a structured vulnerability triage process.

References

Jacobs, J., Romanosky, S., Edwards, B., Roytman, M. and Adjerid, I. (2021) 'Exploit Prediction Scoring System (EPSS)', *Digital Threats: Research and Practice*, 2(3), pp. 1–17. doi: 10.1145/3436242.

Johnson, P., Lagerström, R., Ekstedt, M. and Franke, U. (2018) 'Can the Common Vulnerability Scoring System be trusted? A Bayesian analysis', *IEEE Transactions on Dependable and Secure Computing*, 15(6), pp. 1002–1015.

Wunder, J., Kurtz, A., Eichenmüller, C., Gassmann, F. and Benenson, Z. (2024) 'Shedding light on CVSS scoring inconsistencies: A user-centric study on evaluating widespread security vulnerabilities', *2024 IEEE Symposium on Security and Privacy (SP)*, pp. 1102–1121. doi: 10.1109/SP54263.2024.00058.

My Peer Response

by Séba Daher - Tuesday, 16 June 2026, 6:03 AM

(Evidence: <https://www.my-course.co.uk/mod/forum/discuss.php?d=370797#p749744>)

Hi Peer B,

Your clearest contribution is the distinction between severity and likelihood. Your example of a low-CVSS vulnerability with a high chance of exploitation is well chosen, because it shows precisely what a severity-only score misses. EPSS speaks directly to that gap.

It is worth noting that EPSS reaches beyond the alternatives Wunder et al. (2024) themselves list, as the authors discuss SSVc, LICALITY and a Twitter-based exploitation model by Chen et al. rather than EPSS by name. I read that as a strength, since you have looked past the paper to the system now most widely adopted for exploit prediction.

The harder question is whether EPSS genuinely improves on CVSS or simply repeats its weakness on a different axis. EPSS estimates the probability of exploitation, but it says nothing about the impact on a given organisation (Jacobs et al., 2021). CVSS captures severity and overlooks likelihood; EPSS captures likelihood and overlooks consequence. Risk depends on both consequence and uncertainty, not either alone (Aven and Thekdi, 2025). Replacing one with the other therefore trades a single-axis measure for another single-axis measure, rather than resolving the deeper issue.

This is why EPSS may be strongest as an input rather than a replacement. Its likelihood estimate becomes most useful when it feeds a decision, for example the exploitation step of a framework such as SSVc, which can weigh likelihood against impact and stakeholder context. Seen this way, EPSS and CVSS are not really competitors. Each gives only part of the picture, and a sound decision method should bring the two together.

Perhaps the more useful question is not which score to keep, but whether any single number, of severity or of likelihood, can ever carry a prioritisation decision on its own.

References

Aven, T. and Thekdi, S. (2025) Risk Science: An Introduction. 2nd edn. Oxon: Routledge.

Jacobs, J., Romanosky, S., Edwards, B., Roytman, M. and Adjerid, I. (2021) 'Exploit prediction scoring system (EPSS)', Digital Threats: Research and Practice, 2(3), article 20. doi:10.1145/3436242.

Wunder, J., Kurtz, A., Eichenmüller, C., Gassmann, F. and Benenson, Z. (2024)
'Shedding light on CVSS scoring inconsistencies: a user-centric study on evaluating
widespread security vulnerabilities', 2024 IEEE Symposium on Security and Privacy
(SP), pp. 1102-1121. doi:10.1109/SP54263.2024.00058.